

Information privacy, also known as data privacy or data protection, is the relationship between the collection and dissemination of data, technology, the public expectation of privacy, contextual information norms, and the legal and political issues surrounding them.

Various types of personal information often come under privacy concerns. Privacy concerns exist wherever personally identifiable information or other sensitive information is collected, stored, used, and finally destroyed or deleted – in digital form or otherwise. Improper or non-existent disclosure control can be the root cause for privacy issues. Informed consent mechanisms including privacy policies and dynamic consent are important in communicating to data subjects the different uses of their personally identifiable information.

History

In 1890, legal scholars Samuel D. Warren II and Louis Brandeis published "The Right to Privacy", an article explaining "the right to be let alone," which helped establish a right to privacy in the United States. Their guidelines set the foundation for how privacy can be understood in terms of personal data, and influenced the development of the privacy laws of the United States.

In the United States, the Privacy Act of 1974 represented an achievement in information privacy law. The law set a Code of Fair Information Practice to govern how federal agencies collect personal information and data. After the Watergate and COINTELPRO scandals involving illegal government use of surveillance, this privacy law was intended to help restore public trust in the government. The Act allowed a person to have the right to access information about themselves and know how their information would be used.

The growth of the internet's popularity in the early 2000s presented different privacy concerns as many companies and organizations began to collect user's personal data. Scholars such as Daniel Solove explained the importance of informed consent.

In 2018, the Facebook–Cambridge Analytica data scandal introduced new privacy risks to the

public. A consulting firm called Cambridge Analytica collected personal user data from over 85 million Facebook users without informed consent. The data collected was used to assist in politically targeted ads during the 2016 U.S. presidential election. This resulted in the United States Federal Trade Commission fining Facebook \$5 billion. The Cambridge Analytica scandal influenced new legislation such as the European Union's General Data Protection Regulation.

Types of information privacy

Data privacy issues may arise in response to information from a wide range of sources, such as:

Healthcare records

Criminal justice investigations and proceedings

Financial institutions and transactions

Biological traits, such as genetic material

Residence and geographic records

Privacy breach

Location-based service and geolocation

Web surfing behavior or user preferences using persistent cookies

Academic research

Financial

Information about a person's financial transactions, including the amount of assets, positions held in stocks or funds, outstanding debts, and purchases can be sensitive. If criminals gain access to information such as a person's accounts or credit card numbers, that person could become the victim of fraud or identity theft. Information about a person's purchases can reveal a great deal about that person's history, such as places they have visited, whom they

have contact with, products they have used, their activities and habits, or medications they have used. In some cases, corporations may use this information to target individuals with marketing customized towards those individual's personal preferences, which that person may or may not approve.

Internet

The ability to control the information one reveals about oneself over the internet and who can access that information has become a growing concern. These concerns include whether email can be stored or read by third parties without consent or whether third parties can continue to track the websites that someone visited. Another concern is whether websites one visits can collect, store, and possibly share personally identifiable information about users.

The advent of various search engines and the use of data mining created a capability for data about individuals to be collected and combined from a wide variety of sources very easily. AI facilitated creating inferential information about individuals and groups based on such enormous amounts of collected data, transforming the information economy.

The FTC has provided a set of guidelines that represent widely accepted concepts concerning fair information practices in an electronic marketplace, called the Fair Information Practice Principles. But these have been critiqued for their insufficiency in the context of AI-enabled inferential information.

On the internet many users give away a lot of information about themselves: unencrypted emails can be read by the administrators of an e-mail server if the connection is not encrypted (no TLS), and also the internet service provider and other parties sniffing the network traffic of that connection are able to know the contents.

The same applies to any kind of traffic generated on the Internet, including web browsing, instant messaging, and others.

In order not to give away too much personal information, emails can be encrypted and browsing of webpages as well as other online activities can be done anonymously via anonymizers, or by open source distributed anonymizers, so-called mix networks.

Nym and I2P are examples of well-known mix nets.

With social media and e-commerce sites being used more frequently, there are more potential openings for stealing consumer's data. Companies can see which types of products consumers like to purchase and can use targeted ads to try to make people purchase more items thinking that this is what they will want to purchase. However, sometimes this type of data is used without explicit consent.

Users are unaware of all of the personal information that is collected about them. Cookies track browsing data and location settings show where a person is based out of, and can show shops or products that are physically located near someone. These combined that be a big safety and privacy issue for users if their data is not being stored safely.

With laws like the California Consumer Privacy Act (CCPA), people's data can be protected and they asked for explicit consent before using said data. Globally, many nations are trying to implement similar clauses to protect consumers.

Email is not the only internet content with privacy concerns. In an age where increasing amounts of information are online, social networking sites pose additional privacy challenges. People may be tagged in photos or have valuable information exposed about themselves either by choice or unexpectedly by others, referred to as participatory surveillance. Data about location can also be accidentally published, for example, when someone posts a picture with a store as a background. Caution should be exercised when posting information online. Social networks vary in what they allow users to make private and what remains publicly accessible. Without strong security settings in place and careful attention to what remains public, a person can be profiled by searching for and collecting disparate pieces of information, leading to cases of cyberstalking or reputation damage.

Cookies are used on websites so that users may allow the website to retrieve some information from the user's internet, but they usually do not mention what the data being retrieved is. In 2018, the General Data Protection Regulation (GDPR) passed a regulation that forces websites to visibly disclose to consumers their information privacy practices, referred to as cookie notices. This was issued to give consumers the choice of what information about their behavior they consent to letting websites track; however, its effectiveness is controversial. Some websites may engage in deceptive practices such as placing cookie notices in places on the page that are not visible or only giving consumers notice that their information is being tracked but not allowing them to change their privacy settings. Apps like Instagram and Facebook collect user data for a personalized app experience; however, they track user activity on other apps, which jeopardizes users' privacy and data. By controlling how visible these cookie notices are, companies can discreetly collect data, giving them more power over consumers.

Educational

In the United Kingdom in 2012, the Education Secretary Michael Gove described the National Pupil Database as a "rich dataset" whose value could be "maximised" by making it more openly accessible, including to private companies. Kelly Fiveash of The Register said that this could mean "a child's school life including exam results, attendance, teacher assessments and even characteristics" could be available, with third-party organizations being responsible for anonymizing any publications themselves, rather than the data being anonymized by the government before being handed over. An example of a data request that Gove indicated had been rejected in the past, but might be possible under an improved version of privacy regulations, was for "analysis on sexual exploitation".

Cable television

This describes the ability to control what information one reveals about oneself over cable television, and who can access that information. For example, third parties can track IP TV programs someone has watched at any given time.

Academic research

Within academia, Institutional Review Boards function to assure that adequate measures are taken to ensure both the privacy and confidentiality of human subjects in research.

Data breaches and privacy risks

When an individual or group of people steal consumer's data it is considered a breach of data. It is a common threat to one's information privacy. This includes information such as names, date of birth, credit card information, and social security numbers.

These types of data breaches can happen when companies do not have the most current or secure infrastructure to secure and encrypt data. A small gap can open data to being leaked from outsiders. It should also be noted that breaches can happen from inside employees exposing information too. Companies are investing time in teaching about suspicious activity and using multi factor authentication systems.

On a federal level in Europe, governments are now mandating that companies report breaches in a timely manner. In America HIPAA functions in a similar way and notifies patients when data has been exposed. With types of guidelines in place, companies and countries are working to protect personal information and explain how personal data can and should be used.

Laws surrounding information privacy are important for protecting information globally. This includes laws that ensure data is collected with consent and is used with transparency.

In the continent of Europe, a guideline called The European Union's General Data Protection Regulation requires everyone to ask for consent before using consumer data and to limit the

amount of data companies need to take from users in general. The European Union's General Data Protection Regulation has shown success, and has prompted other nations to follow suit. For example, the state of California and the country of Canada decided to create and implement their own version of the European Union's General Data Protection Regulation. California created the California Privacy Rights Act (CPRA, 2020) and Canada created the PIPEDA (Government of Canada, 2021), both modeling their guidelines on The European Union's General Data Protection Regulation that puts consumer and user data and privacy right's first.

More broadly, the U.S. collectively is still working on creating a comprehensive program that can protect data within the many sectors of jobs and companies operating out of the U.S. However, there are smaller guidelines and policies for each organization. For example, HIPAA or Health Insurance Portability and Accountability Act protects medical patient data and information. This is not on a national level that protects all user data from different types of companies, but in the U.S. there are organization and industry level protections created.

Artificial intelligence and privacy

Artificial intelligence can be seen as a hindrance to protecting information privacy as they collect data widely. According to the International Association of Privacy Professionals, about 68% of consumers globally express concern about their privacy online with 57% agreeing that AI can be a threat to their data. These concerns have intensified as generative AI tools, which learn from data scraped from the web, have become more widely adopted.

AI privacy concerns can be linked to unregulated data collection methods, opaque algorithms, and data persistence. Algorithmic opacity means not understanding exactly how and where AI is getting their data and sources from.. The lack of clear visibility can make it difficult for someone to understand how their information is being found and used. Data persistence is data existing for an extended period of time online that can also be without consent.

As of now in the United States there are not any explicit federal laws governing AI in terms of data collection. Laws such as the Health Insurance Portability and Accountability Act (HIPAA) and Gramm Leach Bliley Act can regulate companies but it excludes AI. There are state legislatures being enacted. The state of Utah in the United States passed the Artificial Intelligence Policy Act in March of 2024. The White House Office of Science and Technology Policy created the "Blueprint for an AI Bill of Rights" in 2022 which explained frameworks for data privacy and AI and having AI systems collect user consent prior to using their data.

Many researchers have created additional frameworks to address AI and data privacy including data minimization requirements, auditing of AI, and giving users an option to opt out of data collection when using AI.

Locational

As location tracking capabilities of mobile devices are advancing (location-based services), problems related to user privacy arise. Location data is among the most sensitive data currently being collected. A list of potentially sensitive professional and personal information that could be inferred about an individual knowing only their mobility trace was published in 2009 by the Electronic Frontier Foundation. These include the movements of a competitor sales force, attendance of a particular church or an individual's presence in a motel, or at an abortion clinic. A recent MIT study by de Montjoye et al. showed that four spatio-temporal points, approximate places and times, are enough to uniquely identify 95% of 1.5 million people in a mobility database. The study further shows that these constraints hold even when the resolution of the dataset is low. Therefore, even coarse or blurred datasets provide little anonymity to the person.

Medical

People may not wish for their medical records to be revealed to others due to the

confidentiality and sensitivity of what the information could reveal about their health. For example, they might be concerned that it might affect their insurance coverage or employment. Or, it may be because they would not wish for others to know about any medical or psychological conditions or treatments that would bring embarrassment upon themselves. Revealing medical data could also reveal other details about one's personal life. There are three major categories of medical privacy: informational (the degree of control over personal information), physical (the degree of physical inaccessibility to others), and psychological (the extent to which the doctor respects patients' cultural beliefs, inner thoughts, values, feelings, and religious practices and allows them to make personal decisions).

Physicians and psychiatrists in many cultures and countries have standards for doctor–patient relationships, which include maintaining confidentiality. In some cases, the physician–patient privilege is legally protected. These practices are in place to protect the dignity of patients, and to ensure that patients feel free to reveal complete and accurate information required for them to receive the correct treatment.

To view the United States' laws on governing privacy of private health information, see HIPAA and the HITECH Act. The Australian law is the Privacy Act 1988 Australia as well as state-based health records legislation.

Children's privacy

Children's online privacy is subject to legal protections in many ways. In the United States, the Children's Online Privacy Protection Act of 1998 monitors the collection of personal information of children under 13 years of age. The law specifically states that website operators must receive parental consent before collecting personal data of children.

The Children's Online Privacy Protection Act of 1998 applies to websites, apps, and all internet based devices that are geared towards children or know that they are collecting data from children under the age of thirteen. Violating this law can result in penalties up to \$43,792 per

violation as it is enforced by the Federal Trade Commission. Additionally, there are state attorneys general that enforce this law.

The Federal Trade Commission has continued to update the Children's Online Privacy Protection Act to meet the current update of emerging technology. There was an amendment made in 2013 that expanded the categories of personal information to include persistent identifiers, geolocation data, and any media with a child's description. The Federal Trade Commission opened another review of the Children Online Privacy Protection Act in 2019 as well in order to monitor new technologies due to children utilizing mobile devices.

Some have noted that the Children's Online Privacy Protection Act does have its limitations. The law at this time does not prevent children from accessing inappropriate content or lying about their age. Moreover, there have been some doubts regarding how comprehensive the Children's Online Privacy Protection Act with educational technology.

Political

Political privacy has been a concern since voting systems emerged in ancient times. The secret ballot is the simplest and most widespread measure to ensure that political views are not known to anyone other than the voters themselves—it is nearly universal in modern democracy and considered to be a basic right of citizenship. In fact, even where other rights of privacy do not exist, this type of privacy very often does. There are several forms of voting fraud or privacy violations possible with the use of digital voting machines.

Legality

The legal protection of the right to privacy in general – and of data privacy in particular – varies greatly around the world. Laws and regulations related to Privacy and Data Protection are constantly changing; it is seen as important to keep abreast of any changes in the law and to continually reassess compliance with data privacy and security regulations.

Data protection laws

Data protection laws across the globe aim to secure personal information and safeguard individual privacy in a digital era. The European Union's General Data Protection Regulation (GDPR) sets a high benchmark, emphasizing consent, transparency, and robust accountability by imposing strict penalties. Many countries adopt similar principles, mandating that organizations implement effective security measures, respect user rights, and notify breaches. In regions such as North America, Asia, and Oceania, data protection frameworks vary from sector-specific regulations to comprehensive legislation. Globally, these laws balance innovation with privacy, ensuring that personal data is appropriately accessible, managed ethically while mitigating misuse and cyber threats.

Authorities by country

Safe Harbor program

The United States Department of Commerce created the International Safe Harbor Privacy Principles certification program in response to the 1995 Directive on Data Protection (Directive 95/46/EC) of the European Commission. Both the United States and the European Union officially state that they are committed to upholding information privacy of individuals, but the former has caused friction between the two by failing to meet the standards of the EU's stricter laws on personal data. The negotiation of the Safe Harbor program was, in part, to address this long-running issue. Directive 95/46/EC declares in Chapter IV Article 25 that personal data may only be transferred from the countries in the European Economic Area to countries which provide adequate privacy protection. Historically, establishing adequacy required the creation of national laws broadly equivalent to those implemented by Directive 95/46/EU. Although there are exceptions to this blanket prohibition – for example where the disclosure to a country outside the EEA is made with the consent of the relevant individual

(Article 26(1)(a)) – they are limited in practical scope. As a result, Article 25 created a legal risk to organizations which transfer personal data from Europe to the United States.

The program regulates the exchange of passenger name record information between the EU and the US. According to the EU directive, personal data may only be transferred to third countries if that country provides an adequate level of protection. Some exceptions to this rule are provided, for instance when the controller themselves can guarantee that the recipient will comply with the data protection rules.

The European Commission has set up the "Working party on the Protection of Individuals with regard to the Processing of Personal Data," commonly known as the "Article 29 Working Party". The Working Party gives advice about the level of protection in the European Union and third countries.

The Working Party negotiated with U.S. representatives about the protection of personal data, the Safe Harbor Principles were the result. Notwithstanding that approval, the self-assessment approach of the Safe Harbor remains controversial with a number of European privacy regulators and commentators.

The Safe Harbor program addresses this issue in the following way: rather than a blanket law imposed on all organizations in the United States, a voluntary program is enforced by the Federal Trade Commission. U.S. organizations which register with this program, having self-assessed their compliance with a number of standards, are "deemed adequate" for the purposes of Article 25. Personal information can be sent to such organizations from the EEA without the sender being in breach of Article 25 or its EU national equivalents. The Safe Harbor was approved as providing adequate protection for personal data, for the purposes of Article 25(6), by the European Commission on 26 July 2000.

Under the Safe Harbor, adoptee organizations need to carefully consider their compliance with the onward transfer obligations, where personal data originating in the EU is transferred to the US Safe Harbor, and then onward to a third country. The alternative compliance

approach of "binding corporate rules", recommended by many EU privacy regulators, resolves this issue. In addition, any dispute arising in relation to the transfer of HR data to the US Safe Harbor must be heard by a panel of EU privacy regulators.

In July 2007, a new, controversial, Passenger Name Record agreement between the US and the EU was made. A short time afterwards, the Bush administration gave exemption for the Department of Homeland Security, for the Arrival and Departure Information System (ADIS) and for the Automated Target System from the 1974 Privacy Act.

In February 2008, Jonathan Faull, the head of the EU's Commission of Home Affairs, complained about the US bilateral policy concerning PNR. The US had signed in February 2008 a memorandum of understanding (MOU) with the Czech Republic in exchange of a visa waiver scheme, without consulting before with Brussels. The tensions between Washington and Brussels are mainly caused by a lesser level of data protection in the US, especially since foreigners do not benefit from the US Privacy Act of 1974. Other countries approached for bilateral MOU included the United Kingdom, Estonia, Germany and Greece.

Technical measures

There are techniques to improve privacy, privacy-enhancing technologies, and privacy software tools. People building and updating systems can use privacy by design and privacy engineering strategies and techniques. For example, by converting data into a non-readable format, encryption prevents unauthorized access.

See also

Computer science specific

Organisations

Scholars working in the field

References

Further reading

Philip E. Agre; Marc Rotenberg (1998). Technology and privacy: the new landscape. MIT Press. ISBN 978-0-262-51101-8.

Koopman, Colin (2019). How We Became Our Data: A Genealogy of the Informational Person. Chicago: University of Chicago Press. ISBN 978-0-226-62658-1.

External links

International

Factsheet on ECtHR case law on data protection

International Conference of Data Protection and Privacy Commissioners

Biometrics Institute Privacy Charter

Europe

EU data protection page

UNESCO Chair in Data Privacy

European Data Protection Supervisor Archived 2008-12-19 at the Wayback Machine

Latin America

Latin American Data Protection Law Review

North America

Privacy and Access Council of Canada

Laboratory for International Data Privacy Archived 2019-08-12 at the Wayback Machine at Carnegie Mellon University.

Privacy Laws by State

Journals

IEEE Security & Privacy magazine

Transactions on Data Privacy